

— EXECUTIVE SECURITY BRIEFING

The Compliance Gate for Code

Entering

Our GitHub Organization

A unified, automated control point that stands between every uploaded project and production — enforcing secrets hygiene, secure-coding standards, supply-chain integrity, and AI-era risk controls before a single line ships.

20+

INTEGRATED ENGINES

6

GATE PHASES

0

SILENT BYPASSES

Every new codebase is a new blast radius — until it passes the gate

Code brought into our organization — by engineers, contractors, or increasingly by AI coding assistants — is the single largest source of unmanaged risk in the software supply chain. Ignite closes that gap with one automated, non-negotiable checkpoint applied to **100% of onboarded projects**.



Breach exposure, cut at the source

Leaked credentials, vulnerable dependencies, and insecure patterns are caught before code ever reaches a repository a threat actor can reach.



Audit-ready by default

Every decision — pass, block, or human-justified override — is attributed, timestamped, and logged. Evidence for SOC 2, ISO 27001, and EU AI Act reviews is a byproduct, not a project.

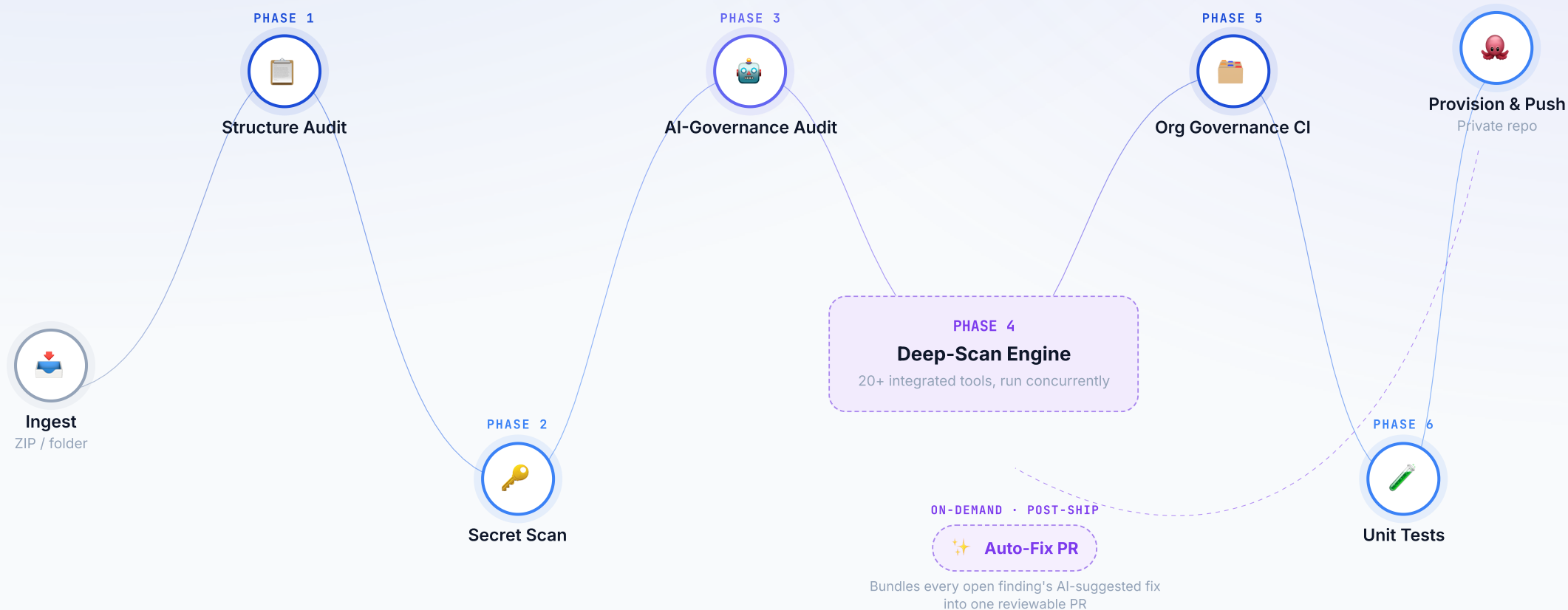


Security that doesn't slow delivery

Fully automated and parallelized — engineering teams get a pass/fail verdict in minutes, with one-click AI-drafted fix PRs instead of a ticket queue.

One pipeline, six gates, zero silent exceptions

Every upload flows left to right through independent checkpoints. A single failed gate halts the run — nothing reaches GitHub without every phase clearing, or a justified, attributed override.



Static analysis & secret detection

The first line of code-level defense — every one of these engines is a category leader, not an in-house heuristic.

Semgrep SEMGREP, INC.

OWASP-aligned static-analysis engine covering 30+ languages; the default SAST layer for security-mature engineering orgs and CI/CD pipelines industry-wide.

CodeQL GITHUB / MICROSOFT

Cross-file, cross-function taint-tracking engine powering GitHub Advanced Security — catches injection and IDOR chains single-file scanners miss entirely.

Bearer BEARER.COM

Purpose-built PII / GDPR data-flow analysis — traces sensitive data from source to sink for privacy-risk and regulatory-exposure reporting.

Gitleaks OPEN-SOURCE STANDARD

The most widely deployed open-source secret scanner — entropy + regex detection before a commit ever leaves staging.

Picklescan AI-ERA ADDITION

Opcodes-level scan of ML model artifacts (.pkl/.pt/.bin/.ckpt) for malicious deserialization payloads — a risk vector standard SAST tools were never built to see.

Supply chain, container & infrastructure security

The tooling that closed the SolarWinds- and Log4j-class gap: what's inside the artifact, and can its origin be trusted.

Trivy AQUA SECURITY / CNCF

The de-facto standard for container image, IaC misconfiguration, and dependency vulnerability scanning.

Checkov PALO ALTO NETWORKS

Policy-as-code IaC compliance across Terraform, CloudFormation, and Kubernetes manifests.

Syft & Cosign SIGSTORE / LINUX FOUNDATION

CycloneDX SBOM generation plus Sigstore-backed signature verification for supply-chain integrity.

GuardDog DATADOG SECURITY RESEARCH

Heuristic inspection of npm/PyPI packages for malicious behavior before they're trusted.

hadolint OPEN-SOURCE STANDARD

Dockerfile best-practice linting — unpinned base images, missing non-root USER, caught pre-build.

AI-era risk & compliance governance

Risk vectors that didn't exist five years ago — purpose-built for a world where a meaningful share of committed code is AI-generated or AI-assisted.

Package-Hallucination Guard IGNITE, BUILT-IN

Live registry checks against npm / PyPI / crates.io catch "slopsquatting" — an LLM-invented package name an attacker already registered.

oasdiff OPEN-SOURCE STANDARD

Diffs every API spec against its prior committed revision to catch breaking changes and shadow endpoints.

Spectral STOPLIGHT

OpenAPI / AsyncAPI governance linting against organizational schema standards.

Compliance & Posture Engine IGNITE, ON SEMGREP

Classifies SSO / RBAC / audit-logging / encryption posture, plus EU AI Act Art. 5, 12, 13 & 50 signals.

CodeQL Cross-File Analysis GITHUB / MICROSOFT

The `security-extended` query suite, applied whole-project — closing the gap when a tainted-data chain spans a controller, a service layer, and a template.

zizmor TRAIL OF BITS

Audits every committed GitHub Actions workflow for pwn requests, script injection via untrusted `$` expansions, and over-broad permissions — the CI-pipeline supply-chain risk a source-code scanner never sees.

GHAS is one engine in the gate, not the gate itself

GHAS is genuinely best-in-class for what it does — Ignite runs its CodeQL engine directly. The difference is scope and timing: GHAS secures a repo that already exists; Ignite decides whether the repo gets created at all.

CHECK	 GHAS	 IGNITE
Secret scanning	✓ Push protection + scanning	✓ Gitleaks + custom regex
Static analysis (SAST)	✓ CodeQL only	✓ CodeQL + Semgrep + Bearer
Dependency vulnerabilities	✓ Dependabot	✓ Trivy + SBOM diffing
IaC & container misconfig.	– Not covered	✓ Trivy, Checkov, hadolint
SBOM & signature verification	 Dependency graph only	✓ Syft SBOM + Cosign signing
PII / GDPR data-flow analysis	– Not covered	✓ Bearer
AI package-hallucination check	– Not covered	✓ Package-Hallucination Guard
Pre-push blocking gate	– PR annotation only	✓ Blocks provisioning until fixed/overridden

Not a replacement for GHAS where it's already licensed — Ignite folds it in as one of twenty-plus engines behind a single go/no-go gate.

Best-in-class tooling, applied consistently, with a paper trail

No engine in this stack is an unproven internal script — each is either the recognized leader in its category, or a purpose-built Ignite control for a risk class those vendors don't yet cover. The value isn't any single scanner; it's that all of them run **every time, on every project, with no exceptions that aren't logged.**



Consistent enforcement

One gate, zero exceptions for who's uploading — engineer, contractor, or agent.



Regulator-ready evidence

Attributed overrides and full scan history, on demand — no scramble before an audit.



Board-level assurance

A single control the executive team can point to, backed by industry-standard tooling.



Recommendation: keep Ignite as the single mandatory onboarding gate; expand override-review cadence to quarterly board visibility.

END OF BRIEFING